

Research paper

The unpredictability of phishing susceptibility: results from a repeated measures experiment

Teodor Sommestad * and Henrik Karlzén

Swedish Defence Research Agency, FOI Totalförsvarets forskningsinstitut, 164 90 Stockholm, Sweden

*Corresponding author. Cyber defence and C2 technology, FOI Totalförsvarets forskningsinstitut 164 90 Stockholm, Sweden. E-mail: teodor.sommestad@foi.se

Received 8 January 2024; revised 22 August 2024; accepted 4 October 2024

Abstract

Phishing attacks via email remain a popular and cost-effective alternative for attackers looking to penetrate computer networks. A number of experiments suggest that a person's susceptibility to this type of deception depends on the phishing email. In field experiments, three variables found to be important are: the scam represented in the email, to what extent the email has been adapted to recipient, and to what extent influence techniques are used. These variables have intricate interdependencies, and the overall scam of the message often constrains how the message can be adapted using influence techniques. In this study, a multilevel model is used. Scam is added cluster variable, and the other two are added as predictor variables. Thus, variations in the overall scam are controlled for before the effect impact of adaptations and use of influence techniques is estimated. In total, 2294 emails were sent to 102 participants and it is measured if they click links provided in emails ($N = 1953$) or run executables referenced in emails ($N = 2199$). The results show that the difference in scam in the message results in 6% variance in susceptibility to phishing links, and 3% variance in susceptibility to executing code. When controlling for the scam, no robust relationships were found between the remaining variables and phishing susceptibility. It is discussed if previous research has overestimated the impact of adaptation and influence techniques, e.g. because of the interdependency between the variables and the scam.

Keywords: phishing; social engineering; fraud; cyberattacks; information security

Introduction

Phishing is a deception technique that involves prompting a person to perform an act. It often occurs via email. For instance, an attacker might send an email that appears to originate from the IT department's address to an employee, requesting the recipient to download and run new (malicious) software. Such deception makes it difficult to cope with the threat of phishing. The benefits of email and other electronic communication are considerable, and, as Williams et al. [1] found by interviewing computer users, the strategy of not clicking on any links received in emails is feasible only in cases where such links are not perceived as necessary for work activities.

Phishing susceptibility, measured as the probability that a recipient performs the action requested in a fraudulent message, has been reported in phishing tests conducted by the industry as part of awareness campaigns. Quinkert et al. [2] reported an analysis of 420 000 phishing emails sent by a consulting company, and the measured sus-

ceptibility rates ranged from 3% to 34%. Cofense [3] reported summary statistics from emails sent in 2022 as part of an awareness-raising activity. In these tests, 13% of the recipients opened email attachments; 7% clicked on links in the emails; and 2% provided their credentials.

Understanding the determinants of phishing susceptibility is valuable, particularly for providing effective security training and establishing approaches to evaluate the effectiveness of various interventions. Accordingly, a number of studies have investigated how the attributes of a message relate to susceptibility in order to, e.g. inform the training of people to recognize dangerous phishing emails. In the review by Sommestad and Karlzén [4], the three variables increasing phishing susceptibility most were reported to be the scam (e.g. if the email concerns a password reset or software update), personalization (e.g. if the email uses personal salutation), and the use of influence techniques (e.g. if the email claims to come from an authority). Beliefs

concerning these variables are influencing training efforts and informational material. For instance, the US Federal Trade Commission [5] suggests you should beware of certain phishing scams (e.g. concerning suspicious account activity), consider how adapted the email is (e.g. if it has a generic greeting), and the use of influence techniques (e.g. claims that an online account is on hold). There are good reasons for these warnings, as the review by Sommestad and Karlzén [4] suggest. However, there are inherent interdependencies between these three variables, and previous research has not studied them in relation to each other. Therefore, this study tested three hypotheses to explore if susceptibility to phishing emails is influenced by the:

- (i) Scam represented in the email.
- (ii) Number of adaptations added to personalize the email to the recipient.
- (iii) Number of influence techniques added to the email.

These variables have complex relationships with each other, making it challenging to manipulate them independently. For example, it is common and straightforward to refer to authority in a phishing message concerning a missed payment, but reference to authority would be out of place in a phishing message concerning a lottery win. Similarly, it is possible to personalize emails pretending to make a job offer, but personalizing a message simulating an automated voice-mail notification would be awkward. Because of these complex relationships, a multilevel model was used in this study to test the four hypotheses. The multi-level model, depicted in Fig. 1, first fits the variance in susceptibility to the overall scam of the phishing email (level 2). Thereafter, the remaining variance is fitted to the other two variables (level 1). Thus, the overall scam is controlled for when the importance of the presentation is estimated.

The remainder of this paper is structured as follows: the section “Related works” describes related works, particularly the research on the importance of the scam, adaptations, and influence techniques. In the section “Materials and methods” presents the materials and methods used in the study, including the phishing emails used. In the section “Results” describes the results in terms of the relative importance of different variables. In the section “Discussion,” the results and their implications are discussed. In the section “Conclusions” presents the conclusions.

Related works

Phishing has been a problem for a considerable time and a large number studies have investigated variables associated with phishing susceptibility. Many of these studies cover variables associated with the recipient (e.g. training) or the situation (e.g. cognitive load). Recent reviews of such variables’ influence on phishing susceptibility are available [6] [7] [8]. However, this paper is focused on how variables associated with the phishing message influence phishing susceptibility. Fewer studies can be found on these message variables. The sections below describe work based on observations in field settings related to the scam of the message (hypothesis 1), to the adaptation for personalization (hypothesis 2), and to the use of influence techniques (hypothesis 3).

Importance of the scam

Phishing emails tend to present a (fictive) story to the recipient and request an action from the recipient. In this paper, we refer to this overall story as the scam. Data from real-world phishing emails, as reported by Cofense [9], suggest that scams on financial themes are effective. Of the ten most effective phishing campaigns recorded in

2018, seven used the word “invoice” in the subject, and the other three on the top ten list pertained to financial statements and payments. In a recent report, Cofense [10] still report finance themes to be the most common (48% of phishing emails), although without specifying subjects further. Other analyses found other frequently used themes in real-world phishing emails. For instance, in phishing emails detected by Expel [11], the most common subject line was, by far, an empty one, followed by “Fax Delivery Report” and “Business Proposal Request,” “Request,” “Meeting,” and “You have (1*) New Voice Message,” indicating that these scams are believed to be effective by attackers, and suggesting that the scam is regarded as important by those sending phishing emails.

While observational reports from practitioners suggest that scams matter, no studies that were explicitly designed to evaluate the effectiveness of different scams have been found in the scholarly literature. Sommestad and Karlzén [4] identified 39 cases where two different scams could be compared with each other, and reported that the average difference in susceptibility was a factor of 5.9 between such pairs. One study with comparable scams was conducted by Goel et al. [12], who obtained a susceptibility of 20% on an email concerning an iPad, but less than 1% on emails concerning a credit card. Another example is the study by Quinkert et al. [2], in which the susceptibility rates for the scams ranged from 3% to 34%. Thus, different scams are clearly associated with different susceptibility levels.

Importance of message adaptation

In the phishing context, an established idea is that messages with attributes that are personalized, or adapted to the recipient, produce higher susceptibility rates. Emails tailored to the recipient are often referred to as spear phishing. These emails may, for instance, address the recipient by name or purport to come from a colleague. The present study modifies email templates containing the scam in such ways.

Numerous field studies have been performed to compare people’s susceptibility to messages adapted this way. For instance, Harel et al. [13] included personalized salutation in some emails; Bowen et al. [14] compared messages with an internal URL to messages with an external URL; Flores et al. [15] tested emails in English against those using the local language; Sokol et al. [16] compared emails originally written in English with automated and manual translations to emails in the local language; Jagatic et al. [17] tested emails appearing to come from strangers and from friends; Jensen et al. [18] varied the use of the organization’s name in the message to adjust for the recipients role (student, staff, or faculty); Marett and Wright [19] varied the domain of the email address and used a personal salutation; and Moody et al. [20] tested known and unknown senders.

The majority of these tests found a positive relationship between adaptation and susceptibility. For example, in the study by Sokol et al. [16], 0.2% provided credentials using phishing emails in English; 1.1% provided credentials using automated translations; and 3.5% provided credentials using manual translations. In another example, Moody et al. [20] found an odds ratio of 2.0 between emails with known senders and those with unknown senders.

Importance of influence techniques

Another established idea in phishing is that various influence techniques can be used to increase people’s susceptibility to the phishing message. Stajano and Wilson [21] presented seven principles related to computer scams: distraction, social compliance, herd, dishonesty, deception, time, and needs-and-greed. Some studies adopt general

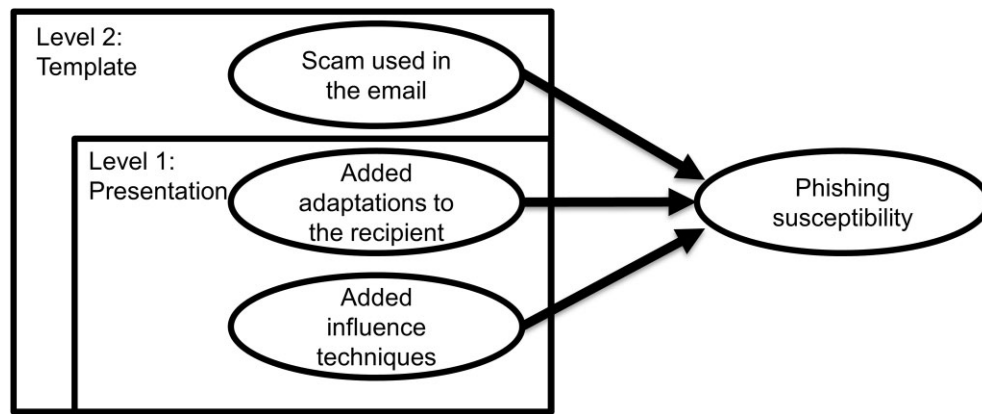


Figure 1. Illustration of the variables in the model, with level 1 variables nested within level 2 variables.

theories on deception and persuasion, such as the principles of influence known as Cialdini's principles [22], which are reciprocity, social validation, commitment/consistency, friendship/liking, scarcity, and authority. The present study modifies emails to apply such influence techniques while keeping the scam intact, e.g. by specifying deadlines or adding flattery at the end of the message.

Empirical tests have evaluated whether the use of such principles influences phishing susceptibility. Lin et al. [23] measured the effectiveness of phishing using seven influence techniques and six scams, the latter termed life domains, in combinations with other factors such as age and gender. Younger participants were most susceptible to scarcity, while older adults were most susceptible to reciprocity. The study also measured scams, but did not evaluate influence techniques while controlling for the scams. Quinkert et al. [2] measured the susceptibility associated with seven different influence techniques. The susceptibilities ranged from 7% in messages designed to have a financial appeal to 15% in messages designed to flatter the recipient. A similar approach was used by Tian et al. [24], who rated eight scams with respect to liking, social validation, reciprocity, and authority. The ratings were used to test the influence of these scams in a logistic regression model, where all variables exhibited statistically significant relationships to susceptibility, which was attributed to interactions with the industry the recipient worked in. Unfortunately, the effects of influence techniques were confounded by the differences in the overall scam in both of these studies.

Wright et al. [25] investigated the importance of influence techniques while controlling for the scam. This was done through text substitutions by inserting six different influence techniques into a message with a template scam. The prediction model explained 11% of the variance in susceptibility, with five of the six influence techniques and gender being statistically significant predictors with odds ratios in the range of 0.6–3.5. However, two points should be noted concerning this result. First, the email recipient's gender was one of the more influential variables in the model. Second, references to authority were associated with reduced susceptibility, contrary to theoretical expectations and later reports of how typical phishing emails are constructed [26].

Importance of variable interdependencies

As discussed above, there are inherent interdependencies between the scam, adaptations, and influence techniques. Previous research has not always disentangled the scam from other variables, making it challenging to determine the scam's relative significance, and pos-

sibly confusing the scam with other variables. For example, in the design by Quinkert et al. [2], emails with different scams were classified to use influence techniques and adaptations, but the scam as such was not analyzed independently. They found that some email scams (e.g. those pertaining to internal information) are more successful, and inferred that this is because of certain influence techniques that are associated with the email. Another example of a design can be found in the study by Harel et al. [13], who compared personalized emails on parking spaces with generic emails on COVID-19. Thus, comparisons have been made between emails with different scams.

In the present study, the scam is managed as an email template on which adaptations and influence techniques are added. The approach is similar to that of Wright et al. [25], who manipulated influence techniques, and Jensen et al. [18], who manipulated adaptation by adding recipient names etc. However, unlike those studies, the present one includes also the scam as a variable. In this study, a catalog of scams is tested and the scam is used as a separate variable entered to the prediction model before other variables.

Materials and methods

The present study measured phishing susceptibility of 102 participating individuals over a period of 16 months, whereby simulated phishing emails were sent to their work email. Considerable effort was made to ensure that the phishing simulations were representative, of the less intrusive type, and balanced in various ways. The sections below detail the participants, phishing simulations, susceptibility measurements, statistical analyses, as well as ethical and legal concerns.

Participants

The present study was conducted in a framework involving employees of Swedish organizations in societally important sectors. The Swedish Civil Contingencies Agency, who sponsored the research, considers the following sectors to meet that requirement: energy, food, transport, healthcare services, financial services, electronic communications, and services related to safety or security.

Public registries were used to produce a list of Swedish organizations providing such services. The organizations in the list were prioritized based on the extent to which their operations concentrated on the relevant sectors, and on whether contact information of the employees in charge of information security could be found. Because of the duration of the study, organizational stability was

sought, and only organizations with more than 100 employees were considered. After this filtering and prioritization, a recruitment period of eight months was initiated in late 2019. Emails and phone calls were used to contact suitable representatives of these organizations, asking them if they would be interested. Common reasons for declining participation in the study were the invasiveness of phishing emails, confidentiality, issues related to the ongoing pandemic, and the lengthy study period. The researchers did not reject any interested organization that fit the above study criteria.

Organizations who were willing to participate were encouraged to nominate workgroups to be included in the study. These nominated workgroups had to comprise a minimum of five individuals engaged in daily computer-related activities. Seven workgroups from three organizations were enrolled to start in April 2020, and four groups from two other organizations joined the study in September 2020. Throughout the study, a total of 159 employees worked in these workgroups. Consent to participate was gathered in writing from each participant after informing about the study without revealing details about how “risky computer behavior” would be measured. Of the 159 employees, 102 individuals from 10 workgroups chose to participate in the study.

The statistical power of this sample was deemed sufficient to test the hypotheses. For a phishing susceptibility of 5%, approximately 1300 emails across participants are needed to measure a statistical effect with for an odds ratio of 1.3 in the logistic regression model ($\alpha = 0.05$, $\beta = 0.20$). The number of emails sent in this study was considerably higher than 1300, and the effect sizes reported in previous research were significantly higher than 1.3.

Email generation

The emails were in general constructed based on knowledge of real-world phishing emails and reflected the type of emails received in the organizations included in the study. A set of 47 templates was created. These templates represented different scams. The emails' scams pertained to the following themes: suspicious user activities ($N = 2$), revisions ($N = 2$), computer changes requiring attention ($N = 3$), lottery wins ($N = 3$), meetings or appointments ($N = 3$), vacation schedules ($N = 3$), speaker engagements ($N = 3$), salaries ($N = 3$), inventories ($N = 3$), missed chat messages ($N = 3$), missed fax messages ($N = 3$), invoices ($N = 6$), and private images or other private matters ($N = 10$). The scams would either request the recipient to open or run an attachment ($N = 10$), download and run a file ($N = 35$), or to simply click on a link ($N = 2$). The files were .docm word files with macros ($N = 20$), .xlsm excel files with macros ($N = 20$), and exe-files ($N = 15$). All emails were adapted to the Windows operating system, as this was the standard among participants. With the exception of one email, all emails were written in the local language, Swedish.

The application of these scams involved some textual processing to vary the emails' content and presumed appeal, applying established influence techniques, and adapting them to the recipient. Two examples of phishing emails (translated from Swedish) that could be generated for a John Doe working at ACME Enterprises are given in Table 1. One email uses no adaptation or influence technique; the other has two adaptations (salutation and signature) and uses one influence technique (scarce time). The variations were randomized and scripted for each individual email.

As in many previous studies (cf. section “Importance of influence techniques”), adaptation was often varied using the salutation phrase, sender, or signature phrase. Other examples of variations included, but were not limited to, adding the organization's name,

adding the name of the work group, and adding the name of a colleague of the recipient by saying that the colleague recommended emailing the recipient.

Influence techniques were drawn from previous research (cf. section “Importance of message adaptation”) and covered seven variations of social validation (e.g. stating that colleagues had already performed an action), twelve variations of scarcity (e.g. stating a firm deadline to access material), six variations of reciprocity (e.g. stating that the IT department worked overtime and now needed help), four variations of authority (e.g. referring to managers' requests), and four variations of liking (e.g. flattering the recipients in relation to their past performance). The randomization did not cover the influence technique of commitment/consistency.

The randomization resulted in two measures for each email. One measured the number of adaptations added (range 0–2 adaptations, mean 0.70) and the other measured the number of influence techniques added (range 0–1 influence techniques, mean 0.16).

Email delivery

The phishing emails were sent during office hours from email domains purchased by the researchers. The scam of each email and the time of sending were randomized. Thus, for each email, one of the 47 scams would be selected at random, further modified randomly as described above, and assigned a scheduled delivery time. In the first four months of the study, the frequency was set to one email every 8–14 days. In the remaining 12 months of the study, one email was sent every 19–25 days.

To provide ecological validity in terms of how emails appeared to participants, no special measures were taken to whitelist the emails. Consequently, many emails were flagged as suspicious, potentially harmful, or tagged as originating from external sources before they were presented to the participants. However, IT departments and security departments at the recipients' organizations were kept informed about the campaign and the domains used. The involvement of IT departments made it possible to verify that the emails were not completely filtered out by automatic systems (e.g. domain reputation systems), and making it straightforward for IT departments to distinguish simulated phishing from real phishing (e.g. when they were reported). No organization intentionally blocked in central systems the emails or the websites.

One potential risk in studies such as this one is that some participants warn colleagues (also participants) about the phishing email. The variation in how emails were constructed and scheduled for the participants meant that two people in the same workgroup seldom received emails with the same scam within the same time period, and almost never received identical copies of the same email throughout the study. This reduced the likelihood that the phishing susceptibility would be biased by warnings of the participants' colleagues.

Susceptibility measurement

Emails with a scam containing a link to a web page (37 scams and 1953 emails) had a unique link for each particular email and recipient. Most of these scams (35 templates and 1858 emails) had a link to a downloadable file. The file contained executable code, either an embedded VBA macro or exe-file, making a web request when executed. Emails based on templates with attached files (10 templates and 341 emails) had the same type of file as those provided by the web links. All links led to a simple web server housed by the researchers. Each request could therefore be registered and related to particular emails, files, and participants.

Table 1. Example of emails with and without added adaptations and influence techniques.

Condition	No adaptation or influence techniques added	Two adaptations and one influence technique
Template	Suspicious user activities 1	Suspicious user activities 1
From	customersupport@(domain redacted).se	customersupport@(domain redacted).se
Subject	Anomalous activity on your computer	Anomalous activity on your computer
Body	Hello! We have discovered anomalous activities on your computer and cannot check this over the network. We need your help to execute a program that sets the configuration for the domain correctly. http://downloads.(domain redacted).se/files/vekfs Thanks in advance!	Dear John Doe. We have discovered anomalous activities on your computer and cannot check this over the network. We need your help to execute a program that sets the configuration for the domain correctly. http://downloads.(domain redacted).se/files/kdkws If you do not do this within one week, your computer will be removed from the domain. Thanks in advance, IT-department, ACME Enterprises

A number of controls were inserted into the requested data to ensure that only the actions of humans were considered. The most important of these controls was to remove requests made by automated link scanners employed in some organizations. For example, organizations with scanners frequently make multiple requests within three minutes from when the email is sent; in organizations without link scanners, no request is made within six minutes. All requests made within four minutes were therefore removed.

Some emails led to considerably more interaction than other emails. In extreme cases, the file was downloaded more than one hundred times and executed more than one hundred times, in requests by more than one hundred IP addresses. While the number of interactions varied significantly, the study measured susceptibility as two dichotomous measures. Any clicked link was counted as a (one) recipient susceptible to clicking links, and any execution of the attachment of downloaded files was recorded as a (one) recipient susceptible to execute code.

Statistical model and analysis

Analyses were conducted on each of the two susceptibility measures: the proportion of emails that were clicked and the proportion of emails that prompted file execution. Logistic regression was constructed for each of the susceptibility measures (clicking links and executing code). To control for the differences in scams, a multilevel model was used.

To test hypotheses 1–3, the full sample of emails were fitted to a random-intercept model with two parameters. This random intercept model had the structure of a traditional logistic regression model with an added parameter u_{0s} that estimated the unique base susceptibility for each scam. In other words, the model adjusts to each scam with different susceptibility and can control for this when the weight of adaptations and influence techniques are estimated. More formally, the model has email messages m nested under scams s and is expressed as follows:

$$\ln \left(\frac{\text{susceptibility}_{sm}}{1 - \text{susceptibility}_{sm}} \right) = (B_{00} + u_{0s}) + B_{10} \times \text{ADAPTATIONS}_{sm} + B_{20} \times \text{TECHNIQUES}_{sm}$$

Hence, the susceptibility for message m of scam s is a log odds function of

- the overall constant, B_{00} as well as the scam-specific constant, u_{0s}

- the weight of the adaptation level in the overall sample, B_{10}
- the number of adaptations for message m of scam s , ADAPTATIONS_{sm}
- the weight of the influence techniques in the overall sample, B_{20}
- the number of influence techniques for message m of scam s , TECHNIQUES_{sm} .

As customary in statistical tests of multilevel models, simple models are compared with more complex ones by assessing each model's fit to the data [27]. A model with fixed intercept (B_{00}) is compared to a model with random intercept ($B_{00} + u_{0s}$). Thereafter, fixed slopes (B_{10} and B_{20}) are added to the random intercept model. A package for mixed models in the software Jamovi was used to test the models [28]. The influence of predictor variables is estimated using odds ratios. The overall fit of prediction models was assessed using variance explained and conditional relative deviance. Variance explained (R^2) and corresponds to McFadden's method for logistic regression, by comparing the prediction model with the null model. Deviance is twice the difference between log-likelihood of the prediction model and a model with perfect fit. A model with good fit explains much variance and has a low deviance.

Ethical and legal concerns

To deal with ethical and legal issues of the research, we followed the guidelines described in the review by Somestad and Karlzén [4]. This work mostly consisted of getting the required approvals, and of minimizing participant risks in relation to their rewards, as presented below.

The study was approved formally by a governmental ethics board as well as by each participating organization. Informed consent was obtained from each participant. The document explicitly mentioned that some sort of deception would occur, but the kind of deception was not specified. No false information was provided in the consent forms. The reason for not specifying all details of the study was that such details would likely alter the ecological validity of the study. It is common for phishing field studies to withhold some information on the deception, as concluded in the reviews by Somestad and Karlzén [4] and by Thomopoulos et al. [29]. The researchers advised the IT departments not to reveal too much about the phishing emails when they were reported by users. There was no explicit debriefing of each participant, but participant work groups received feedback on the study results, and organizational representatives were invited to a seminar on the study and its results. Each participant also had

the contact details of the lead researcher. No complaints about the phishing study were received.

In total, 2294 emails were sent to 102 recipients. Overall susceptibility was in terms of clicking links 6.4% (125 out of 1953 emails), and in terms of executing code 3% (66 out of 2199 emails). Among these samples, 1858 emails contained links to executables and are used to measure susceptibility in both ways. Table 2 describes four models for predicting the susceptibility of clicking links (C1–C4) and four models for code execution (E1–E6). Sections “Importance of scam–Importance of influence techniques” describe how the models in the table relate to the hypotheses.

To minimize impact on the work performance of participants, the phishing email campaign was no less intrusive than real phishing campaigns. In particular, no passwords or other credentials were collected, and the files were not malicious or harmful to the computers. Legally, the study was regulated primarily by governmental ethics approval, the EU data protection regulation (GDPR), and other laws concerning the protection of data. To avoid any copyright-related issues, all internet domains used in the study were chosen carefully, not to clash with existing corporations’ names or brands.

Results

Importance of scam

In the dataset, the susceptibility rates to scams ranged between 0% and 19% for the different scams. Thus, the scams are associated with variations in susceptibility. The fit of models C1 and E1 in Table 1 corresponds to the importance of scams, explaining 6% variance in click rate and 3% variance in execution. This result also holds for models C2–C4 and E2–E4, where additional parameters are added. Thus, while the effect sizes are low, the data support hypothesis 1. The scam of the message appears to play a role.

Importance of message adaptation

A regression weight was introduced for the number of message adaptations added was in models C2 and E2. The estimated odds ratios for this parameter was 1.42 for clicking links and 1.08 for execution of code, suggesting that increased adaptation elicits a slight increase in susceptibility to phishing. However, this parameter is not statistically significant in the model for code execution, and there is no improvement in the fit of any of the models compared to the scam parameter alone. The results are similar when the use of influence techniques is controlled for in models C4 and E4. These mixed results provide only a weak support for the importance of adaptation (hypothesis 2).

Importance of influence techniques

A regression weight was introduced for the number of influence techniques added in models C3 and E3. The influence of the parameters is not statistically significant in any model, and the overall fit shows no improvement when this parameter is introduced. Thus, the use of influence techniques does not appear to increase susceptibility to phishing, and there is no support for hypothesis 3. Furthermore, the best estimate for effect sizes is in the opposite direction to what established theories suggest, with odds ratios below around 0.8.

Discussion

This study used data collected from a field study to test three hypotheses concerning employees’ susceptibility to phish-

ing emails. Table 3 summarizes the results in relation to these hypotheses.

The section below discusses these results further. The section “Validity and reliability” analyzes the validity and reliability of the study. The section “Alternative interpretations of results” discusses some alternative interpretations of the results. The section “Comparison with previous research and results” interprets the results of this study in the context of previous research. The section “Suggestions for future research” presents suggestions for future research. The section “Implications for practice” describes the implications for practice.

Validity and reliability

In conducting phishing field experiments, there are several issues with validity and reliability. In general, this study dealt with various confounders by balancing randomization in the email design and changing the order of emails. It is hard to identify any issue with the study that would bias the result in terms of the relative importance of different variables. However, there are several reasons to suspect that effect sizes are lower than they would be in a real-world phishing situation, where a threat agent sends one specific email to one specific person. These aspects pertain to the validity of the studied population, the way the phishing messages are constructed, and the duration of the study, as discussed below.

Participants were recruited to this study from Swedish organizations in societally important sectors. As participant recruitment to the study was difficult, there may be a selection bias. For instance, organizations who are confident in their security management practices, and individuals interested in information security, may be overrepresented among those chosen to participate. Alternatively, such organizations and individuals may feel their security stances are so strong that there is no point in participating in a study aiming to improve security. Another factor is that organizations in societally important sectors may be more likely to face serious threats or have access to particularly good technical phishing filters, thereby resulting in lower susceptibility rates compared to other populations. Furthermore, there is some reason to believe that employees of organizations in different national cultures would behave somewhat differently. However, a previous field experiment on phishing found only weak support for national culture in regards to resistance to phishing [30].

Concerning the phishing emails, it would have been trivial to construct a dataset with samples yielding larger effect sizes for the scams by sampling a wider range of scams or using completely idiotic scams or very powerful scams tailored to the organizations in the study. The current dataset is instead a representation of typical scams in real phishing emails, with consideration for the harm inflicted to recipients and others. More specifically, care was taken to avoid emails that might cause personal harm to the recipients, and real company logos and names were avoided. For example, none of the emails mentioned compromised accounts, in order to not worry participants, and no file or domain name was used with real company names other than participant companies. An attacker would probably be less considerate and could therefore construct more attention-grabbing emails that would look more authentic.

The duration of the study may also have lowered susceptibility rates. The study was unusually long and probably longer than most phishing campaigns that threat agents run. Therefore, participants were exposed to situations allowing them to learn from phishing simulations. In particular, participants interacting with the emails might have learned how to recognize upcoming emails or get used to emails

Table 2. Models used to predict susceptibility for clicking links and executing code. ^a

Dependent variable	Sample size	Model label	Independent variables ^a			Overall fit		Fixed effects (odds ratios)		
			Scam	Added adaptations	Added infl. techniques	R ²	Deviance	Scam, $e^{B_{00}}$	Number of adaptations, $e^{B_{10}}$	Number of infl. techniques, $e^{B_{20}}$
Click link	1953	C1	R	–	–	0.06	886	0.06	–	–
Click link	1953	C2	R	F	–	0.06	887	0.06	1.42	–
Click link	1953	C3	R	–	F	0.06	886	0.06	–	0.85
Click link	1953	C4	R	F	F	0.06	887	0.06	1.43	0.81
Execute code	2199	E1	R	–	–	0.03	575	0.03	–	–
Execute code	2199	E2	R	F	–	0.03	576	0.03	1.12	–
Execute code	2199	E3	R	–	F	0.03	575	0.03	–	0.80
Execute code	2199	E4	R	F	F	0.03	576	0.03	1.13	0.79

^aLabels for the independent variables denote if the parameter is random (R), fixed (F), or absent (–) in the model. The fixed effects indicated in bold are statistically significant ($P < 0.05$).

Table 3. Evaluation of support for the tested hypotheses.

#	Hypothesis	Evaluation
1	Susceptibility to phishing emails is influenced by the scam represented in the email.	Supported
2	Susceptibility to phishing emails is influenced by the number of adaptations added to personalize the email to the recipient.	Partially supported
3	Susceptibility to phishing emails is influenced by the number of influence techniques added to the email.	Not supported

being less interesting, making them less likely to click on links and attachments. For instance, the participants might have become accustomed to links not leading to interesting information, and attachments giving errors and no useful information. Trend analyses suggest that when such adaptation or learning occurred the susceptibility drops after the first few months.

All issues described above have the potential to impact the susceptibility rates measured, and their statistical power. For example, if the target population has good filters that label phishing emails as suspicious, fewer participants will interact with the emails, and the statistical power will suffer. Thus, this study may underestimate the susceptibility of people or the amount of variance a scam explains. It is likely that stronger effects can be measured in other populations. However, because of the randomized order of emails, no other bias is expected. For instance, the randomized order of emails balances out the potential learning that occurs throughout the study. Learning is outside the scope of this study. However, it should be noted that learning did appear to occur in the beginning of the study period, and needs to be considered in study designs related to phishing. The first five emails sent to participants with links had a mean susceptibility of 13%, and susceptibility thereafter leveled out to approximately 5%.

Alternative interpretations of results

In addition to the issues related to validity and reliability covered in the section “Validity and reliability,” alternative interpretations could have been made of the data of this study.

First, the design of this study allows for a set of easily modifiable scams. The influence techniques and adaptations added to the scams were calculated relative to the base text of the template associated with the scam. However, some of the scams contained adaptations and influence techniques in the base case. An alternative approach could have been to have a panel rate each scam’s adaptation to the

recipient, and the number of influence techniques used. The following are examples of how this could be implemented for influence techniques:

- Emails sent with an invitation to look at pictures from the last work party invoke curiosity. This could be assessed and rated as an influence technique.
- Requests to provide information related to the asset inventory tend to appeal to authority and duty. This could also be assessed and rated as an influence technique.

This approach has been taken in previous studies (cf. section “Importance of influence techniques”). Some of the variance attributed to scams in our analysis may be attributed to adaptation or influence techniques with this approach. That is, the regression weights (i.e. odds ratios) may be different. In any case, the regression weights will still explain less variance than the model as a whole (3% and 6%), and the importance of influence techniques can still be questioned with such small effect sizes. In addition, it would result in a blurry definition of what constitutes the base-scram, dependent on the judgment of the panelists.

Second, one could have considered other response variables than those used in this study. For example, it could have been measured how many times participants reported the emails, executed each code instead of merely indicating whether they executed the code at all, as well as how many machines executed each code. Data are available on the number of clicks and executions associated with each email. These numbers are unevenly distributed. The most clicked link was clicked 619 times from 179 unique IP addresses. The file provided from this link was executed 185 times from 122 unique IP addresses. However, only 19 emails had their link clicked more than 10 times. We do not believe that the number of interactions with an email is a better measure of its impact than a dichotomous measure of interacting or not interacting. Almost all emails sent in this study also involved ensuing error messages from websites and executables, upon

clicking links. It is therefore natural that some emails are circulated within groups of colleagues and that many employees interact with them, for instance, to try a different way to get access to the promised content hidden by the Word macro. For an attacker, such circulation with lots of instances of susceptibility is of limited value, as one compromised machine behind the firewall is often sufficient, unless a specific recipient is sought. However, it would be reasonable to expect that IT departments can implement better protection against a phishing email that has been reported by a recipient. Steves et al. [31] suggest that metrics such as reporting rates “metrics must be considered in conjunction, not in isolation, as early reporting can greatly improve mitigation efforts.” Unfortunately, such reporting data were not available in this study.

Comparison with previous research and results

The review by Sommestad and Karlzén [4] reported considerably higher effect sizes for the scam, message adaptations, and the use of influence techniques than what is reported in this study. This section tries to explain these differing results by comparing this study to previous ones.

In the review by Sommestad and Karlzén [4], the scam was associated with a relative risk of 5.9, with a 95% confidence interval of 4.3–7.9. That is, when different scams were compared, the mean difference in phishing susceptibility was a factor of 5.9. In this study, 34 scams were clicked at least once. In pairwise comparisons between these 34 scams, the mean difference in phishing susceptibility was a factor of 2.46. The same number for 31 scams executed at least once is 1.9. Thus, this study produced an unusually small difference between scams. One possible explanation for this is that the sample of scams is unusually homogenous, despite our efforts to create variation. Another possible explanation is that the repeated measures design of this study produces more generalized results than studies where emails are sent within a short time period. If all emails are sent in the same time period in the selected population, which is a common design, they may match all the recipients' environment in a particularly good or bad way by chance or design. For example, Ragucci and Robila [32] sent emails to military cadets asking them to confirm their grade reports in a study. They concluded that “[t]iming was key in this experiment because of the subject of the phishing message. The message was sent at the end of the semester, when cadets would be most concerned about their grades.” In the present study, no ideal timing of this would occur by chance because scams are sent to different participants at different points in time, and this study was intentionally designed to avoid the effects of situational variables.

This study measured an odds ratio of approximately 1.4 for the number of adaptations made to the emails. That is, the odds that an email was clicked were 1.4 higher for every adaptation that was added. A more basic measure of the importance of adaptations can be obtained by comparing the click rates of any adaptation with no adaptation: the click rate was 6.9% in emails with adaptations and 4.9% in emails with no adaptations. This corresponds to a relative risk of 1.4, which is well within the 95% confidence interval for relative risk of 1.1–2.0 reported in the review by Sommestad and Karlzén [4]. Accordingly, studies with similar relative risks and odds ratios were reported in the literature. In the study by Moody et al. [20], the susceptibility was 3% for emails with an unknown sender and 5% in emails with a known sender. Similarly, in a study by Sokol et al. [16], the click rate was 5.6% in emails that had been translated automatically in a poor manner and 6.5% in emails with proper local language. Thus, the results of adaptations are similar in several other studies where adaptations were added while controlling for the scam.

This study measured an odds ratio below 1 for the number of influence techniques used in the emails. In pairwise comparisons within scams, click rates were 5.5% with the addition of an influence technique and 5.7% without addition of an influence technique. In other words, susceptibility decreased slightly when emails were modified in accordance with some type of influence technique. This contradicts both the theory and previous studies on phishing. However, as mentioned above, most studies reporting effects of influence techniques do not control for the scam. For example, Quinkert et al. [2] compared emails on leaked passwords with emails on job advertisements, and Goel et al. [12] associated eight different scams with variables that could be classified as influence techniques. In fact, the only previous study that manipulated influence techniques while controlling for the scam is the study of Wright et al. [25], who sent 41 emails without influence techniques and 1312 emails for each of the tested influence techniques. Several of the influence techniques in their regression model were statistically significant predictors. The biggest impact came from liking, while references to authority were associated with reduced susceptibility, contrary to theoretical expectations.

Thus, overall, the effect sizes and results in this study are in line with previous research. The design shows that scams are important, that adaptation increases susceptibility rates by a factor of 1.4 (approximately), and that influence techniques independent of the scam are irrelevant to susceptibility.

Suggestions for future research

This study was not designed to identify the characteristics of the scams leading to high susceptibility rates. Nevertheless, to support future theory development, an explorative post-hoc analysis was performed on the variation between the scams. The analysis explored if richer emails were more successful, if the technical requests in the scam were associated with differences in susceptibility, and if work-related scams were more successful.

The emails associated with the scams were of different lengths and types of requests. However, it is difficult to identify any variables associated with this that are clearly related to susceptibility. For example, there was no correlation between email length and the susceptibilities to click ($r = 0.02$, $P = 0.27$) or execute code ($r = -0.01$, $P = 0.74$).

The requests in the scams differed from a technical perspective. For example, the two scams suggesting that the recipients import holidays into their calendars had different types of executable files. The scam supplying an exe-file was executed by 9% of the respondents, while the one supplying a macro-activated word file was executed by 4%. Similarly, in three scams involving fax messages, the one presenting an exe-file as the way to download the fax was executed more often than those with macro-activated word files (7% vs 4% and 0%). These differences suggest that exe-files are associated with more execution susceptibility. However, overall, scams involving exe-files were not executed more frequently than other scams ($r = 0.03$, $P = 0.21$).

Of the 37 scams requesting participants to click links, 26 concerned work-related matters (e.g. meetings) and 11 concerned private matters (e.g. party pictures). The mean susceptibility rates are 7.3% for work-related scams and 4.1% for those that are unrelated to work. This difference is statistically significant. For susceptibility to execute code, the same numbers are 3.2% and 2.3%, with no statistically significant difference. Thus, respondents may be more susceptible to work-related scams, and this has been studied previously. For example, all the common scams listed by Expel [11] presented in the section “Importance of the scam” concern work-related matters. Greene et al. [33] found that users with a work context

aligned with the premise of phishing emails were especially susceptible. This was illustrated in scams using a phishing email regarding a missed voice call. Users who indeed had missed a call were more susceptible.

In summary, our explorative analysis only produced one promising idea: the potential relevance of scams' relationship to the workplace. Studies that address such variables may explain significantly more variance in phishing susceptibility than models based on the message alone. Therefore, we suggest that more powerful tests be designed along these lines, such as testing if susceptibility rates are higher when emails are constructed based on temporary individual information such as a recipient's to-do list or upcoming events in the workplace. A similar idea would be to study the interaction of scam or influence technique and the recipients' personalities and mood. Norris et al. [34] reviewed papers on the psychology of internet fraud victimization and suggested that happier people pay more attention to positive messages such as fake lottery wins and that happier people rely more on heuristics while less happy people focus on details. It has also been speculated that personality can moderate the success of influence techniques. For instance, Pantic and Husain [35] speculate that appealing to greed is more successful with open-minded people, innocuous emails with the conscientious, confidence-based emails with the extraverted, kindness-related emails with the agreeable, and threatening emails with the neurotic.

Implications for practice

The design of this study separates the scam from the two variables of influence techniques and adaptations made to personalize the email to the recipient. The results indicate that the explanatory power attributed to influence techniques in previous studies may actually be coupled with the scam, and not be due to the influence techniques alone. In other words, the importance of influence techniques may have been overestimated. The study also shows that the effect of personalizing adaptations is quite weak, as indicated in previous research. Thus, it is not crucial for a phishing attacker to adapt to the name of the recipient or where they work in the organization. In other words, "spear phishing" does not appear to be as dangerous as some suggest, and risks associated with exposing employees' names and details may be less than previously thought.

For those designing training interventions and informational material concerning phishing, the results of this study suggest that focus should be placed on the scams, and not adaptations or influence techniques. That is, enumerating examples of phishing scams associated with high susceptibility rates may be a good way of increasing people's ability to handle these phishing threats. The informational material from the US Federal Trade Commission used as an example in the introduction of this paper is a good example of how this can be done: it starts with an enumeration of commonly used scams people should be aware of. Not all informational material is designed this way. For example, the web page of the European Cyber Security Month in 2022 only relates to the scam in two of their eight identifiers (promotional offers and questions for personal information). The other six cover things such as bad spelling, pushes for urgency, and emails not saluting with your first name.

However, the most important practical takeaway from this study is the relative insignificance of the email itself. Together, the three email-related predictor variables (scam, adaptation, and influence techniques) only explain 6% of the susceptibility to click links and 3% of the susceptibility to execute code. In other words, 94% of the

explanation for why people click phishing links and 97% of the explanation for why people execute code from phishing emails must be found somewhere else. Thus, security managers, system administrators, and email recipients who think they can distinguish a dangerous phishing email from an essentially harmless one based on the email alone should probably reconsider. This study suggests that if they can get their prediction model perfectly right, they will only improve their changes of predicting susceptibility rates slightly (< 6% in this dataset). It is clear that more information is needed to make accurate predictions. It is possible that information about recipients' security awareness or a combination of the email content and the recipients' environment will be needed to make predictions of decent accuracy.

Conclusions

The scam used in phishing emails influences the susceptibility of the recipients performing the action requested in the emails. However, in this study, the difference in scams explained only a small variance in susceptibility. None of the other tested variables exhibited a robust relationship to susceptibility. Adaptation of the content of phishing emails to the recipient, such as personal salutation, showed odds ratios above one but did not increase the susceptibility when compared to the scam parameter alone. The use of influence techniques, such as reference to authority, had no positive influence on susceptibility. Overall, the results of this study illustrate the difficulty of predicting susceptibility based on the phishing emails alone.

Author contributions

Teodor Sommestad (Conceptualization [lead], Data curation [equal], Formal analysis [equal], Funding acquisition [lead], Investigation [equal], Methodology [equal], Project administration [lead], Resources [equal], Software [lead], Validation [supporting], Visualization [lead], Writing – original draft [lead], Writing – review & editing [equal]), and Henrik Karlzén (Conceptualization [supporting], Data curation [equal], Formal analysis [equal], Funding acquisition [supporting], Investigation [equal], Methodology [equal], Project administration [supporting], Resources [equal], Software [supporting], Validation [lead], Visualization [supporting], Writing – original draft [supporting], Writing – review & editing [equal])

Funding

This work was supported by the Swedish Civil Contingencies Agency (MSB).

References

1. Williams EJ, Hinds J, Joinson AN. Exploring susceptibility to phishing in the workplace. *Int J Hum Comput Stud* 2018;120:1–13. <https://doi.org/10.1016/j.ijhcs.2018.06.004>.
2. Quinkert F, Degeling M, Holz T. Spotlight on phishing: a longitudinal study on phishing awareness trainings. In: L Bilge, L Cavallaro, G Pellegrino, N Neves (eds), *Lecture Notes in Computer Science*. Vol. 12756. Cham: Springer International Publishing, 2021, 341–60. https://doi.org/10.1007/978-3-030-80825-9_17.
3. Cofense. 2023 Annual state of email security report. 2023. <https://cofense.com/wp-content/uploads/2023/03/2023-Annual-Report-Cofense.pdf> (11 October 2024, date last accessed)
4. Sommestad T, Karlzén H. A meta-analysis of field experiments on phishing susceptibility. In: *eCrime Researchers Summit, eCrime* 2019. Pittsburgh, PA: IEEE, 2019. <https://doi.org/10.1109/eCrime47957.2019.9037502>.

5. US Federal Trade Commission. How to recognize and avoid phishing scams. <https://consumer.ftc.gov/articles/how-recognize-and-avoid-phishing-scams>. (20 August 2024, date last accessed).
6. Baki S, Verma R. Sixteen years of phishing user studies: what have we learned?. *IEEE Trans Dependable Secure Comput* 2022;20:1200–12. <https://doi.org/10.1109/TDSC.2022.3151103>.
7. Zhuo S, Biddle R, Koh YS, et al. SoK: human-centered phishing susceptibility. *ACM Trans Priv Secur* 2023;26:1–27. <https://doi.org/10.1145/3575797>.
8. Burda P, Allodi L, Zannone N. Cognition in social engineering empirical research: a systematic literature review. *ACM Trans Comput Hum Interact* 2024;31:1–55. <https://doi.org/10.1145/3635149>.
9. Cofense. The state of phishing defence. 2018. (12 October 2024, date last accessed). https://www.aquion.com.au/wp-content/uploads/2018/12/The_State_of_Phishing_Defense_2018.pdf.
10. Cofense. Annual State of Email Security. 2024. <https://cofense.com/annualreport/> (11 October 2024, date last accessed).
11. Expel. Quarterly Threat Report Q1 2022. <https://expel.com/wp-content/uploads/2022/05/Expel-QTR-051822.pdf> (11 October 2024, date last accessed) 2022.
12. Goel S, Williams K, Dincelli E. Got phished? Internet security and human vulnerability. *J Assoc Inf Syst* 2017;18:22–44. <https://doi.org/10.17705/1jais.00447>.
13. Hillman Y, Hillman Harel Y, Hillman Toch E. Evaluating organizational phishing awareness training on an enterprise scale. *Comput Secur* 2023;132:103364. <https://doi.org/10.1016/j.cose.2023.103364>.
14. Bowen BM, Devarajan R, Stolfo S. Measuring the human factor of cyber security. In: 2011 *IEEE International Conference on Technologies for Homeland Security, HST 2011*. 2011, IEEE: Boston US. 230–5. <https://doi.org/10.1109/THS.2011.6107876>.
15. Flores WR, Holm H, Svensson G, Ericsson G. Using phishing experiments and scenario-based surveys to understand security behaviours in practice. In: NL Clarke, SM Furnell (eds), *Proceedings of the European Information Security Multi-Conference, EISMC 2013*. Lisbon Portugal. 2013, 79–90. <https://doi.org/10.1108/IMCS-11-2013-0083>.
16. Sokol P, Glova M, Mezešová T, Hučková R. Lessons learned from phishing test. In: VO Gerhard, CD Petr (eds), *IDIMT2017: Digitalization in Management, Society and Economy—25th Interdisciplinary Information Management Talks*. Pödebrady, Czech Republic: Trauner Verlag Universitat, 2017, 297–304.
17. Jagatic TN, Johnson NA, Jakobsson M, Menczer F. Social phishing. *Commun ACM* 2007;50:94–100. <https://doi.org/10.1145/1290958.1290968>.
18. Jensen ML, Dinger M, Wright RT, Thatcher JB. Training to mitigate phishing attacks using mindfulness techniques. *J Manag Inf Syst* 2017;34:597–626. <https://doi.org/10.1080/07421222.2017.1334499>.
19. Marett K, Wright R. The effectiveness of deceptive tactics in phishing. In: *15th Americas Conference on Information Systems 2009, AMCIS 2009*. San Francisco, US. 2009, 2583–91.
20. Moody GD, Galletta DF, Dunn BK. Which phish get caught an exploratory study of individuals' susceptibility to phishing. *Eur J Inf Syst* 2017;26:564–84. <https://doi.org/10.1057/s41303-017-0058-x>.
21. Stajano F, Wilson P. Understanding scam victims: seven principles for systems security. *Commun ACM* 2011;54:70–5. <https://doi.org/10.1145/1897852.1897872>.
22. Cialdini RB, Sagarin BJ. Principles of interpersonal influence. In: *Persuasion: Psychological Insights and Perspectives*. 2nd edn, Thousand Oaks, CA: Sage Publications, Inc, 2005, 143–69.
23. Lin T, Capecci DE, Ellis DM, et al. Susceptibility to spear-phishing emails: effects of internet user demographics and email content. *ACM Trans Comput Hum Interact*. 2019;26:1–28. <https://doi.org/10.1145/3336141>.
24. (Annie) Tian C, Jensen ML, Durcikova A. Phishing susceptibility across industries: the differential impact of influence techniques. *Comput Secur* 2023;135:103487. <https://doi.org/10.1016/j.cose.2023.103487>.
25. Wright RT, Jensen ML, Thatcher JB, et al. Research note—influence techniques in phishing attacks: an examination of vulnerability and resistance. *Inf Syst Res* 2014;25:385–400. <https://doi.org/10.1287/isre.2014.0522>.
26. Ferreira A, Chilro R. What to phish in a subject? In: M Brenner, K Rohloff, J Bonneau, A Miller, PYA Ryan, V Teague, A Bracciali, M Sala, F Pintore(eds), M. Jakobsson. *Financial Cryptography and Data Security*. Cham: Springer International Publishing, 2017, 597–609. https://doi.org/10.1007/978-3-319-70278-0_38.
27. Sommet N, Morselli D. Keep calm and learn multilevel logistic modeling: a simplified three-step procedure using stata, R, Mplus, and SPSS. *Int Rev Soc Psychol* 2017;30:203–18. <https://doi.org/10.5334/irsp.90>.
28. Jamovi. The jamovi project, Version 2.2. <https://www.jamovi.org> (11 October 2024, date last accessed).
29. Thomopoulos G, Lyras D, Fidas C. Methodologies and ethical considerations in phishing research: a comprehensive review. In: *ACM International Conference Proceeding Series*. Athens, Greece: Association for Computing Machinery, 2023. <https://doi.org/10.1145/3609987.3609990>.
30. Flores WR, Holm H, Nohlberg M, Ekstedt M. Investigating personal determinants of phishing and the effect of national culture. *Inf Comput Secur* 2015;23:178–99. <https://doi.org/10.1108/ICS-05-2014-0029>.
31. Steves M, Greene K, Theofanos M. Categorizing human phishing difficulty: a phish scale. *J Cybersecur* 2020;6. <https://doi.org/10.1093/CYBS/EC/YAA009>.
32. Ragucci JW, Robila SA. Societal aspects of phishing. In: *2006 IEEE International Symposium on Technology and Society*. New York, US: IEEE, 2006, 1–5. <https://doi.org/10.1109/ISTAS.2006.4375893>.
33. Greene K, Steves M, Theofanos M, Kostick J. User context: an explanatory variable in phishing susceptibility. In: *Proceedings 2018 Workshop on Usable Security*. Reston, VA: Internet Society, 2018, 1–14. <https://doi.org/10.14722/usec.2018.23016>.
34. Norris G, Brookes A, Dowell D. The psychology of internet fraud victimisation: a systematic review. *J Police Crim Psych* 2019;34:231–45. <https://doi.org/10.1007/s11896-019-09334-5>.
35. Pantic N, Husain M. A decision support system for personality based phishing susceptibility analysis. In: *2018 IEEE International Conference on Big Data (Big Data)*. Seattle, US, 2018, 3066–71. <https://doi.org/10.1109/BigData.2018.8622555>.